BREACHSIEVE - Vulnerability Assessment Report

Target: https://juice-shop.herokuapp.com | Date: 2026-10-17 04:54:53 UTC

Risk Score	Critical	High	Medium	Low	False Positives	Novel Patterns
7.8	0	1	4	0	1	3

Scope & Authorization Record

Target URL	https://juice-shop.herokuapp.com
Scan Mode	ACTIVE (Active Confirmed: 1)
Authorization Status	CONFIRMED - Explicit authorization granted by operator
Authorized At	2026-10-17T04:54:46.616607+00:00
In-Scope Rules	juice-shop.herokuapp.com /rest/* /api/*
Out-of-Scope Rules	/ftp/*

Confirmed Vulnerability Findings (5)

[BS-FIND-001] Anti-clickjacking Header (X-Frame-Options) Not Set - **Medium (CVSS: 5.2)**

CWE: CWE-1021 | **OWASP:** A05:2021-Security Misconfiguration | **MITRE:** T1190
URL: https://juice-shop.herokuapp.com
Description: The response does not include either Content-Security-Policy with 'frame-ancestors' directive or a X-Frame-Options to protect against 'ClickJacking' attacks.
Gemini AI Verdict: [CONFIRMED] Confirmed: HTTP response headers omit both 'X-Frame-Options' and CSP 'frame-ancestors'. The target page can be rendered inside an unauthorized <iframe> layer.
Remediation: Configure 'Content-Security-Policy: frame-ancestors self' and 'X-Frame-Options: SAMEORIGIN'.

[BS-FIND-002] Content Security Policy (CSP) Header Not Set - **Medium (CVSS: 6.0)**

CWE: CWE-693 | **OWASP:** A05:2021-Security Misconfiguration | **MITRE:** T1562
URL: https://juice-shop.herokuapp.com
Description: Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks.
Gemini AI Verdict: [CONFIRMED] Confirmed: No 'Content-Security-Policy' HTTP response header is transmitted by the server.
Remediation: Deploy a strict Content-Security-Policy header.

[BS-FIND-003] X-Content-Type-Options Header Missing - **Medium (CVSS: 6.0)**

CWE: CWE-693 | **OWASP:** A05:2021-Security Misconfiguration | **MITRE:** T1562
URL: https://juice-shop.herokuapp.com
Description: The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body.
Gemini AI Verdict: [CONFIRMED] Confirmed: Missing 'X-Content-Type-Options: nosniff' header enables MIME sniffing vulnerabilities.
Remediation: Send 'X-Content-Type-Options: nosniff' on all text/html and script responses.

[BS-FIND-004] Server Leaks Information via "Server" HTTP Response Header - Medium (CVSS: 6.4)

CWE: CWE-200 | **OWASP:** A01:2021-Broken Access Control | **MITRE:** T1552
URL: https://juice-shop.herokuapp.com
Description: The web/application server can be identified via the 'Server' header field, exposing specific software and version numbers.
Gemini AI Verdict: [CONFIRMED] Confirmed: Scanner detected active reflection of test vector quoting evidence: 'Apache/2.4.52 (Ubuntu) OpenSSL/3.0.2' in response context at 'https://juice-shop.herokuapp.com'.
Remediation: Apply parameterized inputs or contextual HTML entity encoding.

[BS-FIND-006] Reflected Cross Site Scripting (XSS) - High (CVSS: 8.6)

CWE: CWE-79 | **OWASP:** A03:2021-Injection | **MITRE:** T1190
URL: https://juice-shop.herokuapp.com/search?q=%3Cscript%3Ealert(1)%3C/script%3E
Description: A reflected cross-site scripting attack occurs when an application receives untrusted data in an HTTP request and includes that data within the immediate response without validation.
Gemini AI Verdict: [CONFIRMED] Confirmed: Scanner detected active reflection of test vector quoting evidence: '<script>alert(1)</script>' in response context at 'https://juice-shop.herokuapp.com/search?q=%3Cscript%3Ealert(1)%3C/script%3E'.
Remediation: Apply parameterized inputs or contextual HTML entity encoding.

Remediation Summary Matrix

ID	Title	Severity	Actionable Fix
BS-FIND-001	Anti-clickjacking Header (X-Fr	Medium	Configure 'Content-Security-Policy: frame-ancestors self' and 'X-Frame-Options: SAME
BS-FIND-002	Content Security Policy (CSP)	Medium	Deploy a strict Content-Security-Policy header....
BS-FIND-003	X-Content-Type-Options Header	Medium	Send 'X-Content-Type-Options: nosniff' on all text/html and script responses....
BS-FIND-004	Server Leaks Information via "	Medium	Apply parameterized inputs or contextual HTML entity encoding....
BS-FIND-006	Reflected Cross Site Scripting	High	Apply parameterized inputs or contextual HTML entity encoding....

Methodology Note

This assessment was performed using automated OWASP ZAP scanning driven through its REST API, restricted to strictly verified in-scope allow-list rules. Alerts were triaged via Google Gemini API using evidence-based analysis to filter false positives and identify novel patterns. This automated assessment augments, not replaces, comprehensive manual security testing.